SECURITY INFRASTRUTURE DESIGN DOCUMENT

This document describes a security strategy to protect a 50-employee company handling payment data. The goal is to minimize risk through the implementation of effective measures.

- Authentication system

The best practices for authentication require the company to have a good password policy: length requirements, character complexity and checking for the presence of dictionary words. To ensure a secure authentication are necessary:

- Multifactor authentication, a system where the users are authentication by presenting multiple pieces of information or objects, such as gestures, biometric ID, bank card, pin; along with **TOTP**, randomly generates value in conjunctions with the current time to generate one-time password.

This stops brute force attacks even if the password is discovered.

In this way, anyone who wants to access any system, network or application needs to verify that is a secure user.

- External and internal website security

For external website security, we will use the **HTTPS** protocol which utilizes **TLS 1.2** and **AES encryption**.

First, the HTTPS protocol permits secure communications and authentication over a network and use TLS 1.2 grants us:

1. Data being transmitted is protected from potential eavesdroppers.
2. Ability to authenticate both parties communicating.
3. Integrity of messages. Check that message arent´t lost or altered in transit.

Second, Advanced Encryption Standard (AES) is a symmetric block cipher that uses a 128-bit key size and support key length of 128, 192 or 256 bit.

This stops man-in-the-middle attacks.

For internal website we will use a centralized system, the **Lightweight Directory Access Protocol (LDAP)**. This is an open industry-standard protocol for accessing and maintaining directory services. Acts as a central phonebook of users, where the server stores credentials. However, if an attacker uses packet sniffing or promiscouos mode on the office, they could intercept and read employee´s passwords.

To avoid this, we use **StartTLS**. Provides encryption, ensuring that the password remains unreadable while it travels from the employee´s computer to the authentication server.

- Remote access solution

We use **VPN** with **L2TP/IPsec** in **Tunnel Mode**.

IPsec is a protocol that encrypted an IP packet and encapsulating. Then the Tunnel Mode takes over to encrypt and encapsulate the entire IP packet.

All of this, especially VPN, allows employees to work from home safely without exposing internal servers to the internet.

This stops data theft or ransomware attacks.

- Firewall and basic rules recommendations

The first thing to do is to have a **firewall** installed with **implicit deny**.

The firewall filters and inspect packets of data attempting to enter and exit in a network. And the implicit deny is a network security concept where anything not explicit permitted or allowed should be denied.

This stops phishing, spam, malware.

- Wireless security

The risk could be evil twin or rogue AP (Access Point) attacks, so to protect it the solution is used **WPA2-Enterprise (802.1X).**

This method avoids the use of shared password that employees might write in a Post-it. We will use WPA2-Enterprise with the 802.1X standar so that each employee use their own user to connect to WiFi, eliminating the risk of stolen pre-shared key.

This stops brute force, dictionary attacks and rainbow tables.

- VLAN configuration recommendations

We will create three **VLANs**.

1. For employees.
2. For guests.
3. Quarantine VLAN, to exclude suspicious devices during an incident.

This is the best way if an employee accidentally downloads malware, it we won´t be infected the payment servers.

- Laptop security configuration

We will use **full disk encryption (FDE)** and **screen locks**.

FDE is a protocol that encrypt the entire drive of the system, not just sensitive files. Works by automatically converting data on a hard drive into a form that cannot be understood by anyone who doesn´t have the key “undo” the conversation. If an attacker has physical access to the disk, FDE protects from data theft and unauthorized tampering.

Then enforce automatic screen locks after 5 minutes of inactivity to prevent impersonation.

- Application policy recommendations

Renstricting risky software, file-sharing or piracy apps should be banned, because they often carry malware.

Along with, it is recommended to use **whitelistening**. This is a seccurity approach where only approved software is allowed to run on a system. Its effective againts unknown or new malware.

- Security and privacy policy recommendations

For network security, is recommended the **penetration testing**, the practice of attempting to break into a system or network to verify the system in place.

Instead, one important privacy policy is the **principle of least privilege**. The acces to sensitive data should be denied by default. Anyone who needs it must submit a request with clear justification, specifiying which data require and for how long.

This reduces human error.

- Intrusion detection or prevention for systems containing customer data

We will install an **IDS (Intrusion Detection System)**. Operate by monitoring network traffic and analyzing it. They look for matching behavior or characteristics that would indicate malicious traffic.

And to stop the malicious traffic we use **NIPS (Network Intrusion Prevention System)**, which take action againts a suspected traffic. Usually by blocking or dropping the traffic.

It alerts us if someone is attempting to attack the customer database.